

Polaris

The evidence record

A companion to *Polaris, Version 3: the map of the system.*
The map says what the system is. This record says how it was measured, what changed, and what was corrected along the way.

Appendix A The metacognitive map

The ladder below is the paper's answer to the request for an explicit map of Polaris as layers of knowledge and scepticism. Each rung states what the layer knows and what it refuses to take on faith from the rung below. The layers are not exactly the rings of Figure 2, because some rings hold two kinds of knowledge; the rungs follow the implementation. Version 3 adds a rung at the top, for the knowledge the tree cannot check about itself; Figure 15, at the end of the conclusion, draws the ladder.

Table 1: The layers, what checks each, and whether each is needed now or is preparation.

Layer	Name	Checked by	Now or later
L0	Human subject	Nothing in the software; the enrolment tiers keep non-enrolment a named state and the referee keeps the undocumented enrollable	Now
L1	Credential core	C3, the signature triggers, the lifecycle trigger, the C3 model	Now
L2	Structural constraints	The audit-of-record and cascade checks, the CHECK-constraint suite, and the drills that mutate all three mechanisms	Now
L3	Cryptographic evidence	The two-witness checks, the canonical oracle, the attack suite, the migration drill, one outside corpus	Now
L4	Verification and status	The detached-verifier, conformance, offline-verification and status checks; the boundary drill; the SDK mutation drill	Now
L5	Privacy and disclosure	The C2 CHECK and model, the redaction suite and its adversary, the linkability adversary, the Athena person checks	Now
L6	Federation	The topology, manifest, feed, isolation and two-instance checks	Now as protocol; later as institutions
L7	Transparency	The log, gossip, publication and report checks	Now as protocol; later as independent witnesses
L8	Institutional services	The registry, gateway, receipt, timestamp and signing checks	Now between instances
L9	Operations	The HA, region, replica, partition, DR, chaos, capacity and hardening checks; the wind-down drill	Now on drills; later on production hardware
L10	System cognition	The Atlas caps and growth grading, the six Athena checks	Atlas and Athena now; Metis, Myrmex later
L11	Societal boundary	C10's structural absence, the non-goals, the vocation, the claim-discipline checks	Now, and permanent
L12	Agent and web environment	The grant, nullifier and holder-key checks; the residue is a stable handle on any presentation that is not zero-knowledge	Now, with the residue named
L13	Other people's software	Nothing in the tree. The scoreboard records what a named outside party did, on a date, and refuses anything the author ran against the author's own code	One wallet, one hosted suite, one corpus now; everything else later, and not ours to supply

Appendix B Counts at 1.0.0-rc.7, and how they were measured

Every count in this paper was taken from the tree at version `1.0.0-rc.7` (commit `4e74376`, 20 September 2026) by the command beside it, not copied from an earlier document. Where the repository's own stamped number was measured at an earlier version, the version is stated. Where a number is external, the row says whose it is.

Version 3 of this paper was written at `1.0.0-rc.1` and re-measured here. Fourteen of the twenty-six quantities below are unchanged; the rows that moved are marked in the text where they matter. One method changed rather than one number: the route count is the same and the command that produced it no longer is.

Table 2: Counts at `1.0.0-rc.7` (commit `4e74376`) and their method. The tree moves after the measurement; a count taken later can differ, and the commit is what makes each one reproducible.

Quantity	Count	Method
Canonical tables in `01_schema.sql`	45	The file declares 50 `CREATE TABLE` statements, of which five are the default partition children of the partitioned event tables. A migrated deployment holds 52 tables.
Triggers in `06_triggers.sql`	42	`grep -c 'CREATE TRIGGER'`
Triggers in the loaded schema	46	The file's 42, and four declared beside what they guard: one in the migration registry's file, one in `01_schema.sql`, two in `12_v7_constraints.sql`. Read from `pg_trigger` on a loaded and migrated database, excluding internal triggers and the 25 copies PostgreSQL makes on the partitions of partitioned tables
Tables under an append-only trigger	31	The `BEFORE UPDATE OR DELETE` triggers of `06_triggers.sql` and the migrations, by table; the design record names fourteen audit-of-record instances among them
Invariant checks	313	`grep -c '^def check_' polaris_checks/checks.py`, equal to the registered list; each has a detection test with a positive control in `test_checks.py`
Mutation drills	12	Files matching `scripts/polaris-*mutation-drill*`: checks, constraints, triggers, procedures, the zero-knowledge witnesses, the conformance contract, the two SDKs, the OpenID4VP verifier, the application, coverage, the constitution, and moves between modules
Application routes	124	`grep -c '^@app.route('` across `polaris_web/*.py`. The count is unchanged from `1.0.0-rc.1`; the METHOD is not. On 18 September 2026 `app.py` was decomposed into ten route modules, and the old method, which read that one file, now returns 13
CI jobs in `ci.yml`	20	The job keys of the workflow; two more workflows run monthly and weekly, and a manual one publishes
Signed wire formats in the specification	27	Distinct `polaris-*/1` strings in `docs/reference/WIRE-SPEC.md`
Conformance cases	118	The cases of `conformance/cases.json`, across twenty-five artifact types; the frozen version-1 set holds 44
Verdict fields no published case constrains	44	`SURVIVORS_EXPECTED` of `scripts/polaris-conformance-mutation-drill.py`, which the drill holds to its own measurement in both directions: of 89 decision fields across the 27 verifiers the cases reach, 44 survive being forced permissive, and none of them could be constrained by writing a case
Formal models checked in CI	4	`meta/tla/*.tla`; three carry a counterpart configuration they must fail

continued on the next page

Quantity	Count	Method
Drill scripts	80	Files matching `scripts/polaris-*drill.*`, the twelve mutation drills among them
Migrations	45	Files matching `polaris_sql/migrations/*.up.sql`, each with a revert
Operator runbooks and ledgers	21	Markdown files in `docs/operator/`, the index included
Tagged versions	3	`git tag`. At `1.0.0-rc.1` this was 295, one per ship from `v9.30` (16 May 2026) to `v9.466` (15 September 2026). A tag marks a RELEASE and not a ship, so those were removed; what remains is `v1.0.0-rc.1`, `-rc.2` and `-rc.3`, the three published candidates
Test functions defined	2,189	`grep -c 'def test_'` across the product, CLI, check-layer, script, card, simulation, SDK and package suites; a definition count, not a run count
Product tests passing, as stamped by the README	1,030	Measured at `1.0.0-rc.7` on the reference machine, `pytest -q` per suite; three skip without real ML-DSA
Crypto witness tests, as stamped	107 of 112	Measured at `1.0.0-rc.7`, unchanged from `1.0.0-rc.1`; five need a PKCS#11 module or a real KMS key, and CI runs all but the KMS one
OpenID4VP verifier package tests	244	`pytest` in `packages/polaris-oid4vp`; three are the positive control without which the refusals are vacuous
Packages on public registries	4	`polaris-verify`, `polaris-oid4vp`, `polaris-sdk-python` on PyPI; `polaris-sdk-ts` on npm; each verified by installing from the live registry. All four served `1.0.0-rc.1` when Version 3 was written. `1.0.0-rc.3`, published 18 September 2026, is a pre-release: an installer takes it only when asked (`pip install -pre`, the npm tag `next`), and a plain install still resolves `0.1.0`, the last stable release. Read off the live registries on 23 September 2026
Hosted conformance modules	11	The OpenID Foundation's service, 15 September 2026: 7 `PASSED`, 4 `REVIEW`, 0 failures, 0 warnings; the service's own signed exports
External test vectors for ML-DSA-65	58 of 58	Project Wycheproof, pinned to a commit, under both witnesses on every push
Named outside implementations that have presented	1	walt.id Wallet API v2 at a pinned image digest, 15 September 2026; one path, one format
Fixes caused by an external finding	2	The scoreboard's row: the certificate the wallet refused (15 September 2026), and a version stamp an outside reviewer could not read unambiguously (17 September 2026)

The paper's performance numbers are those of Table 6, each with the version that measured it. The application baseline has not been re-run since `v9.191` and is cited with that stamp. The dyno was re-run on 23 September 2026 against the tree at `1.0.0-rc.7`, with the prover rebuilt from it, and the re-run found that its proof measurement had measured nothing since `v9.354`: it still sent the prover an input the prover no longer accepted, printed *not measured here*, and exited cleanly, so its CI step stayed green. The signature rows moved by a few per cent; the proof row fell from 35 ms to 25 ms, and is not like for like, because the statement proved changed at `v9.354`. A half that does not measure now fails the step. The reference machine throughout the repository is an Apple Silicon laptop with eight cores and sixteen gigabytes of memory.

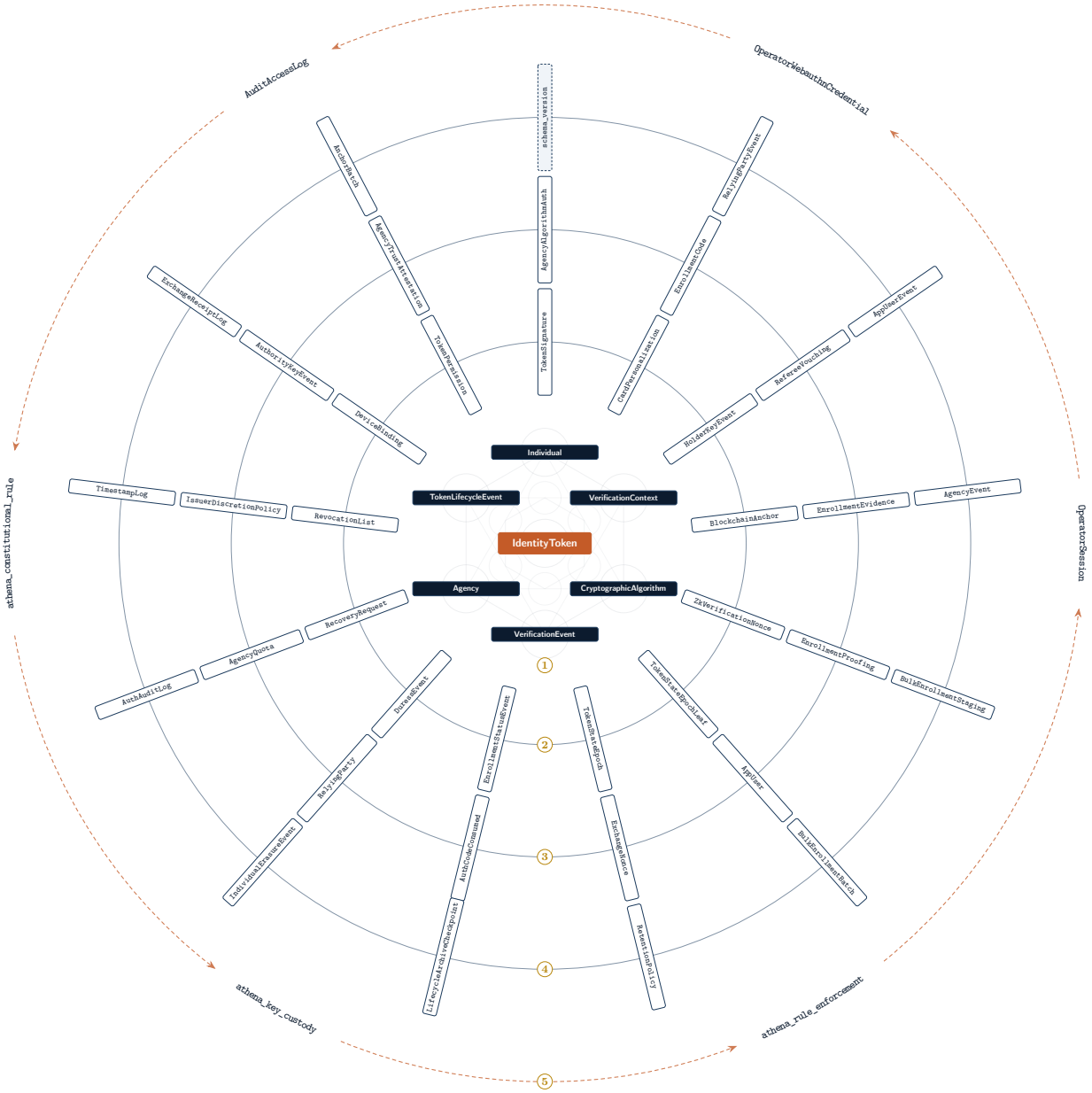


Figure 1: The 45 canonical tables of `01_schema.sql` at `1.0.0-rc.7`, as rings around the nucleus. The faint lattice at the centre is the nucleus geometry of Figure 3 at the same proportions. Ring two is the credential machinery: signatures, permissions, epochs, recovery, duress, the holder's key, the card. Ring three is authority, trust and the people at the counter: who may sign under which algorithm, who trusts whom, revocation ceilings, quotas, relying parties, the replay registers, and what an enrolment rested on. Ring four is the archives, watchtowers and decisions kept as records: append-only logs, anchors, the retention decision as data, and the events that record every change to an authority, an operator account or a relying party. A migrated deployment holds seven more tables, drawn dashed: the migration registry closes the fourth ring, so rings two, three and four have the same thirteen spokes, and the other six (operator sessions, their hardware keys, the audit-access log and Athena's three curated tables) form a fifth, hexagonal ring that echoes the nucleus. Its arrows all turn one way: migrations applied one after another, round the canonical schema. The five partition children are not drawn.

Appendix C From Version 1 to Version 2

Version 1 remains the historical report and is not edited. This appendix records what Version 2 kept, what it corrected, and what it retired, so that a reader of both can reconcile them. Version 3 keeps every decision below unchanged; what it changed against Version 2 is Appendix D.

Kept

- The token-centred entity geometry (Figure 3), reproduced from Version 1 without change and used as the nucleus of every map in this paper.
- The lifecycle state machine (Figure 4), reproduced without change.
- The disclosure-level argument: that the level is a persisted property of the verification record, enforced by a check constraint, and that this is what prevents the verification log from functioning as a surveillance database.
- The argument that post-quantum signing belongs on the first day, through the secrecy horizon of identity data and Mosca's inequality, and the substrate argument that every higher property of an identity system is derivative of its cryptographic primitives. Both are summarised here and stand in Version 1 in full; what Version 3 narrows is the *claim* made about the signatures, not the argument for choosing them (Section 5).
- The comparison of design properties against deployed systems, which this paper does not repeat; the repository's front page carries the current table and marks Polaris as neither deployed nor issuing at national scale.
- The threat-model frame (STRIDE), which the repository's design record now carries with every threat mapped to a control or an explicit acceptance.

Corrected

- Twelve tables became thirty-six at Version 2 and forty-five at Version 3. The three subsidiary entities of Version 1 (device bindings, ledger anchors, the revocation list) remain; the rest of the growth is described ring by ring in Section 4.
- Version 1 stated that the audit tables were append-only by convention and tooling and that the state machine would be enforced by a trigger in a production deployment. Both are now enforced by triggers, and a check fails the build if either stops being.
- Version 1 described the ledger anchor as an optional decentralised-identifier path. The off-chain batch commitment exists and is monitored as a transparency log; publication to an external chain remains an operator action with declared drivers and no live integration.
- Version 1 modelled seven verification contexts with per-context biometric requirements and a physical token with on-device biometric binding. The contexts remain; the physical token is now an encoding, an emulator and a verifier device, and remains unmanufactured.
- The two speculative binding horizons of Version 1's final appendix (genomic and quantum-observer binding) are not carried forward as design. The repository's readiness pass quarantined the speculative schema behind a check that it cannot return, and this paper treats the holder-side key, not a new biometric, as the extension that the future environment needs.

Added

Everything from Section 5 onward describes machinery that did not exist when Version 1 was written: real signing and custody, the two witnesses, the detached verifier and the conformance contract, status and offline authorization, the membership proof and its second witness, the wallet protocol and the broker, federation, transparency, the exchange fabric, the operational drills, Atlas and Athena, the history of self-correction, the societal boundaries, and the future-facing sections on agents, personhood, delegation and outside observers.

Appendix D From Version 2 to Version 3

About this version

Version 1 of this report (`polaris_project_report.pdf`, preserved unchanged beside this file) described Polaris as a database-design project: twelve tables around one credential, an entity-relationship model, a lifecycle state machine, and the argument that identity data must be post-quantum from the first day. Version 2 (`polaris_project_report_v2.pdf`, also preserved) described the system as it stood at tag `v9.345`, thirty-six tables, a federation protocol, a transparency layer and an institutional exchange fabric, and was revised at `v9.355` when the holder-side work it had recorded as missing was built. Version 3 describes the system at version `1.0.0-rc.7` (commit `4e74376`, 20 September 2026), re-measured whole rather than patched, and it is written for a reader who has never opened the repository. It was first written at `1.0.0-rc.1` four days earlier and re-measured in place; fourteen of the twenty-six counts in Appendix B did not move, and the ones that did are marked there.

What changed, in one paragraph. Between Version 2 and this one the repository stopped counting its own progress and started counting witnesses. The four standalone packages a relying party installs are on public registries. A wallet written by somebody else, run unmodified, presented a credential to the verifier and was accepted, after refusing it once for a defect every internal instrument had passed over. The OpenID Foundation's hosted conformance suite ran the verifier profile across the open internet. The verification layer itself was attacked from inside: the checks, the constraints, the triggers, the unique indexes, the stored procedures, the zero-knowledge witnesses, the conformance contract and both reference verifiers were each mutated and required to go red, and many did not, at first. The physical layer became an object somebody else can implement. And two words on the front door were weakened, *post-quantum* to *algorithm agility under an audited migration path* and *compulsion-resistant* to *duress-aware*, because the evidence did not support the stronger ones. Appendix D lists every claim of Version 2 that this version withdraws or narrows.

Three dates, stated plainly. Version 2's body was measured at `v9.345`; its holder-side sections at `v9.355`. Everything in this version, every count, every mark and every figure, was measured at `1.0.0-rc.7` by the methods in Appendix B. Where a number is older than that, because the repository has not re-run the instrument that produced it, the paper says so beside the number. Nothing that ran at `v9.355` stopped running.

The paper keeps what Version 1 got right, the token-centred geometry of the schema, used here as the centre of every map, and the lifecycle machine, and what Version 2 got right, the concentric reading of the system, one ring per section, each ring introduced by the failure of the ring inside it.

Version 2 is preserved unchanged beside this file. This appendix records what changed between them, and, more usefully, which sentences of Version 2 this version can no longer write.

What the system gained

Between `v9.355` and `1.0.0-rc.1`, in the order the rings meet them: what an enrolment rests on, the trusted referee and the enrolment code; the card as an encoding, an emulator, a personalization step and a verifier device, with duress measured in time; decisions about authorities, operators, quotas, ceilings and relying parties kept as append-only records; eight mutation drills over the verification layer and the corrections they forced; four formal models checked on every push; a population migration that runs and is measured; the cache rules that let an untrusted network carry a status; a depth-24 epoch pipeline; a measured statement of what two colluding verifiers can do; a standby region; a capacity model that found an integer column, and a cost model; the public transparency report; the pilot wind-down and the coexistence plan; the machine-checked assurance mapping and the automated third of accessibility; two format bridges; four packages on public registries; the OpenID4VP verifier; the operating contract and the scoreboard; and the first three external nouns on it.

Claims of Version 2 that this version withdraws or narrows

Table 3: Sentences of Version 2 that Version 3 does not repeat.

Version 2 said	Version 3 says	Why
A post-quantum, issuer-unlinkable, compulsion-resistant identity-token system	An issuer-unlinkable, duress-aware identity-token system signed with ML-DSA-65 under an audited algorithm-migration path	Two words weakened by the repository's own assessments; each is now refused by a check on outward surfaces
The default signing algorithm is post-quantum from day one	The algorithm is ML-DSA-65 and the default development and CI path signs a labelled placeholder; production fails closed without real signing	Measured: 32 placeholder bytes where a signature is 3,309
The duress path is a tested property; no external party has measured its side channel	The mechanism resists the casual coercer, not the informed one beside the holder, and is net-negative against lawful access	The lab's assessment against the contract's three coercers
An actual implementation by an external team has not happened	One unmodified outside wallet has presented over OpenID4VP and been accepted; no implementation of the native protocol by anyone else	The scoreboard's wallet row; the boundary between the two paths
The specification and the conformance suite exist; the integration is unproven	The OpenID Foundation's hosted suite ran the profile: 7 passed, 4 in review; a later run against `1.0.0rc7` was certified (24 September 2026)	The Foundation's own signed exports; its certified-implementation listing
Cross-verifier correlation is a permanent, documented property, then bounded	Bounded on the zero-knowledge path within the epoch's crowd, against an adversary that matches equality; exposed on plain and SD-JWT presentations; the crowd has no floor	The linkability lab's three findings
The certificate the verifier signs requests with was correct	It carried no key usage, and every internal instrument had passed it	An outside wallet refused it
The check layer catches its own violation	Seventy-one of seventy-five checks passed on a tree where their property was commented out, and the tests for constraints, triggers, indexes and procedures would often not have noticed their subject missing	The mutation drills; every finding closed and drilled

continued on the next page

Version 2 said	Version 3 says	Why
Thirty-six tables, 26 triggers, 191 checks, 48 conformance cases, 18 CI jobs, 20 formats, 1,048 test functions, 755 and 84 of 89 tests	Forty-five tables, 42 triggers, 272 checks, 118 cases, 20 jobs, 27 formats, 1,755 test functions, 992 and 107 of 112 tests	Re-measured at `1.0.0-rc.1`; Appendix B
Thirteen audit-of-record instances	Fourteen named, thirty-one tables under an append-only trigger	The schema's own triggers, counted
The physical token is modelled and not manufactured	Encoded, emulated, personalized and read by a reference device; not manufactured	`polaris_card/` and its drills
Multi-region recovery is not built	A standby region is built and its non-zero recovery point is measured	The evacuation drill
The roadmap's targets are to be validated	A throughput model built from single-machine measurements clears every target by an order of magnitude under stated assumptions, nothing ran at national scale, and a 32-bit column would have ended the service in five days	The capacity model
The version is v9.355, a count of ships	The version is `1.0.0-rc.7`, moved only by an externally observable change	The operating contract's versioning rule
Future work is a list of things to build	Future work is a list of things outside parties would have to do, questions the lab owes answers to, and items held until somebody outside needs them	The operating contract's merge rule and kill line

What was deliberately not done

The dyno and the application baseline were not re-run, and their rows in Table 6 carried their original stamps; the dyno was re-run on 23 September 2026 (Appendix B). The Version 1 and Version 2 documents were not edited. The repository documents that disagree with the code at `1.0.0-rc.7` were not corrected for the paper; they are listed in the author's notes, as Version 2's were, so that the paper follows the code and the disagreement is not lost.

Vocabulary introduced

A fifth status mark, EXTERNALLY EXERCISED, for a capability a named outside party has exercised, with the rule that it is given only where the scoreboard has a filled row and never means audited, certified or piloted. A thirteenth rung on the ladder, for the knowledge the tree cannot check about itself. And the operating contract's own words, external noun, scoreboard, release candidate, used the way the repository uses them.

Appendix E Provenance: what was learned after the snapshot

This report describes the system at `1.0.0-rc.7`, commit `4e74376`. It was revised after that commit, and some of what it says was learned later. This appendix is the complete list, obtained from `git diff 4e74376` over the paper's sources, of everything outside Appendix F that the snapshot alone would not tell a reader. Each entry is in one of seven classes.

Re-measured, reproducible at the snapshot. Counts taken later by running a command against commit `4e74376`; checking out that commit and running it gives the same number: 313 checks, twelve mutation drills, 80 drill scripts, 45 migrations, 124 routes, 46 triggers, 44 verdict fields, 2,189 test functions of which 1,030 are product tests, 107 of 112 cryptographic tests, 244 tests in the OpenID4VP package, six Athena checks, and the 31/24/7 breakdown of guards.

Repository or registry state, read later. Not reproducible from the commit, because it lives outside it: the three tags; the four packages and what each serves; `polaris-verify` at rc.3; the ninety-day table as read on 23 September (day ten, five of seven); the two outside fixes.

Measured on 23 September. Runtime numbers taken after the snapshot on the same machine: 2,080, 7,950 and 740 verifications per second in the capacity passage, and the proof times of 25 ms and 12 ms.

Events after the snapshot. The OpenID certification of 24 September (Sections on verifiers and limitations, Appendix A, Appendix F, the outside-witnesses figure); the guard-declaration rule of 23 September; the procedure drill's widened scope and its lock test; the trigger deletion measurement (42, 38, 42); the detached verifier drill (45 refusals, 32 survived, seven declared); the password rotation order; the stranger's path and the package READMEs walked on 23 September; and the finding that the proof half of the capacity measurement had measured nothing since `v9.354`.

Corrections of what was already wrong at the snapshot. 143 package tests are 142; 43 verdict fields are 44; "five checks" is six Athena checks; "a few hundred cluster summaries" is at most five thousand; the lifecycle caption (reserve to revoked); the districts caption (seven tables dashed); the identifier-columns wording; the date of the second outside fix.

Written on 25 September, after an outside review. Appendix B of the map and the references; this appendix; the untested-claims table (Table 4); the withdrawal of "Sybil resistance" for credential uniqueness per enrolment identity; the qualification of "validated" for the national targets; the witness taxonomy in Section 8; the minimum anonymity set and its failure semantics (a code change of the same day, in Appendix F); the five percent as a governance parameter; the database owner as the unbound actor; and who chooses the offline window.

Revised on 28 October 2026. Section 19, retitled; the last subsection of Section 20, retitled, and that section's account of the ring, which gained a dated row of 11 October 2026; the conclusion; single lines in Sections 3, 4, 5, 8, 9, 10, 13, 15 and 18, in the map's Appendices A, B and C, and in its front matter; one row of Table 2 in this record; and one dated line in Appendix F.

Editorial changes (layout, the cover image, glossary abbreviations and the re-stamping of `rc.1` as `rc.7`) carry no information and are not listed. The code counts beside `rc.7` in the body are at the snapshot; counts in the README and on the site are at the current tree and differ from them.

Appendix F The corrections record

Section 15 describes the assurance layer as it stands. This appendix is its record: each row is a mechanism that was technically valid and did not prove what was intended, when it was found, and the check, drill or test that now fails if it returns. The tables are chronological and keep the voice of the record; the map in the body does not depend on them.

Up to Version 2

Each row is a mechanism that was technically valid and did not prove what was intended, the version that found it, and the sense it left behind. None of these is embarrassing; each is the method working. Version 2 carried this table, and it is kept.

Table 4: Corrections recorded in the changelog before Version 2. The right-hand column names the check or test that now fails if the original condition returns.

Version	What was believed	What was true, and what changed	The new sense
v9.58	Tokens were post-quantum signed	The procedure wrote a placeholder string and the signing module was an unused island; signing was wired into issuance	`check_pqc_signing_wired`
v9.113	Signatures were verified	Nothing on a live path ever called verify; issuance now self-verifies and a use-path primitive exists	`check_verify_enforced`
v9.133	A verdict from one library was a verdict	One library could silently accept a forgery; a second, independent implementation must agree	`check_pqc_second_witness`
v9.257	The benchmark measured verifications per second; bulk-issued tokens were signed	It measured audit-row ingestion, about 35 times faster than cryptographic verification; bulk rows carried a placeholder literal. Three numbers are now reported separately and bulk issuance refuses an unsigned row	`signatures_cryptographically_verify`, `check_national_simulation`
v9.264	Every stored signature was two-witnessed; `usable` was current	A missing witness at issuance degraded silently to one; `usable` could be decided on a stale replica. Issuance now requires the witness and status is pinned to the primary	`check_pqc_signing_wired` (extended)
v9.272	The single-witness fast path was sound	It was sound only while the fast witness stayed trustworthy, which nothing checked; sampling through the second witness is now mandatory and a disagreement pages	`check_verify_witness_sampling`
v9.302	A transparency monitor caught a lying log	It caught a rewrite and not a split view; witnesses, gossip and the equivocation proof were added	`check_transparency_gossip`
v9.309	The detached verifier rejected hostile input	It crashed on several classes of it; a totality contract converts every crash into the intended reject	`check_verifier_fuzz`
v9.313	The canonical oracle pinned every signed field list	Its static key-list pin used a regex that silently matched nothing; the wire specification is now checked against the signer	`check_wire_spec_matches_code`
v9.333	The exchange gateway authorized by the trust graph	It accepted an attestation from any agency on the instance, transitive trust one layer up; the responder itself must attest	`check_exchange_trust_directional`
v9.334	Long-term validation trusted a timestamp	It trusted any authentic timestamp, including the signer's own, which the signer can backdate; the verifier now names distinct trusted timestamp authorities	`check_ltv_timestamp_trust`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
v9.335	A receipt alone proved an exchange	A dishonest responder can sign any receipt; the requester's envelope beside it is the evidence. A QR decoder with no bound was also made resource-bounded	`check_qr_resource_bounds`
v9.336	The broker enforced a relying party's step-up	The demand arrived only in the holder's request; it is now registered on the relying party's row, and the code is encrypted	`check_broker_policy_bound`
v9.341	Anchored time evidence survived a stolen key	A thief could mint a backdated timestamp; anchoring into a witnessed log makes a forgery one absent from every witnessed head	`check_timestamp_transparency`
v9.345	The maintainer would remember which drills a change touches	A changed verdict shipped without its drills and CI was red for four versions; a tool now names the verification a change needs from the paths and route handlers that moved	`check_ship_tool`

One outcome the changelog recorded before Version 2 is a retired claim rather than a corrected mechanism, and the table above does not carry it. On 4 June 2026 (`v9.91`) the repository's thesis, that a stranger can read it cold and correctly infer what it needs, was recorded as inconclusive, with the strong claim permanently retired: it was never tested by a stranger before its deadline, the `v9.40` terminus, which passed with no external cold read (`docs/THESIS.md`).

Since Version 2: the instruments were asked whether they would notice

Between `v9.357` and `1.0.0-rc.1` the loop was turned on the verification layer itself. The question changed from *does it pass* to *would it notice*, and the answers below are the record. Most of these rows are about the tests rather than the system, which is the point: a guarantee is believed because a check says so, and the checks are written by the same hand as the code.

Table 5: Corrections recorded since Version 2. The right-hand column names the check, drill or record that now fails if the original condition returns.

Version	What was believed	What was true, and what changed	The new sense
v9.384	The national throughput targets were the capacity question	They clear by an order of magnitude, and the system could not have run for a week at them: a 32-bit event identifier is five days at the sustained rate. Five identifiers widened	`check_capacity_model`
v9.387	Six cores would serve the peak	The per-core rate was measured; the multiplication had never been run. Core counts are extrapolated under a named assumption, and a percentile the sample cannot carry is withheld	`check_capacity_model` (extended)

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
v9.389 to v9.393	Thirty-five conformance cases passed; 24 of 44 frozen cases held	With no post-quantum library, every pass was a rejection answered by a verifier that rejects everything; a third tool closed with a guarantee it had skipped. All three refuse to report rather than name a cause	`check_conformance_suite` (executes the runner), the compat suite's void verdict
v9.398, v9.399	The checks read the code	71 of 75 passed on a tree where their property was commented out, because the helper handed them the comments too. Stripped; the exposure is measured on every push	the check-mutation drill
v9.403	A drill that printed its guarantee had tested it	Twenty-two drills printed whole verdict paragraphs from zero recorded cases	`check_drills_count_their_cases`
v9.404	Both internal hops were classical	The posture had been read off base-image versions; one hop had been post-quantum for some time. Read off a real handshake now	`check_internal_kex_measured`
v9.405	A detection test proved its check detects	Fifteen tests only ever asserted failure; a control on the unbroken fixture is now required	`check_detection_tests_have_a_positive_control`
v9.407 to v9.415	The database's guarantees were tested	All 46 CHECK constraints were load-bearing; 14 of 37 triggers and 12 of 17 unique indexes could be dropped with the suite green, and with the one-active-token index absent the suite committed a duplicate. All covered; the sweep is a drill	the three mutation drills, `check_append_only_tables_are_tested_exhaustively`, `check_unique_rules_are_tested_exhaustively`
v9.417, v9.418	The access-control matrix described the routes	Two hand-written lists named 25 of 101 guarded routes; stripping every guard turned 15 of 654 tests red. The matrix is derived from the code, and a CSRF exemption is read rather than assumed	`check_route_guards_are_derived_not_listed`, `check_csrf_exemptions_do_not_trust_the_session`
v9.420 to v9.433	The conformance contract asked what a verifier must check	It verified an identity token's signature and never its audience or nonce; three artifact types had no bad-signature case; five valid vectors had expired; the two SDKs disagreed about replay; the instrument counting all this was wrong three ways	`check_conformance_asks_the_relying_party_question`, the conformance mutation drill
v9.422 to v9.426	Decisions about operators, quotas, relying parties and ceilings were recorded	Six audit event types had no writer; a quota, a relying party's bar and the revocation ceiling could be changed with nothing recorded anywhere. Each is a trigger-written record now, and the first list of missing writers was wrong about three	`check_every_audit_event_has_a_writer`, the audit-of-record checks

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
v9.434 to v9.437	The stored procedures' refusals were tested	27 of 59 could be deleted with the suite green, concentrated where a trigger cannot see; all covered	`check_procedure_refusals_are_mutation_tested`
v9.440, v9.443	The root of the authority hierarchy and the table of who may sign in were recorded	Neither had a trigger; two operator scripts naming columns that never existed had never run in 410 versions. Found against the live catalogue, not by reading	the schema-drift drill, the audit-of-record checks
v9.452 to v9.454	Polaris was post-quantum	Accurate about the algorithm, a claim about Module-LWE as security, and the default path signed a placeholder. The headline is algorithm agility, and a rule rather than prose holds it there	`check_post_quantum_claims_are_agility`
v9.455, v9.456	The reference verifiers refused what they exist to refuse	18 of 18 refusals in the Python SDK and 9 of 14 in the TypeScript one could be inverted with every suite green; all 32 are inverted on every push	`check_sdk_refusals_are_mutation_tested`
v9.459 to v9.462	Five concurrency tests proved serialization	None could fail, one claim lived in a comment, and the local runner read half the file; the tests now carry a contention control	`check_advisory_locks_have_a_contention_test`
v9.465	The verifier's certificates were right	Eleven hosted modules and every internal instrument had passed a request-signing certificate with no key usage; an outside wallet refused it	a test red on a leaf without `digitalSignature`; the scoreboard
2026-09-15	Eleven of eleven hosted modules were clean, awaiting a screenshot	One alias for all eleven made each module interrupt its predecessor; four positives were killed, and the suite had recorded it in the log downloaded to prove the claim. Re-run one at a time: 7 PASSED, 4 REVIEW	the drill's unique alias per test; the scoreboard's status vocabulary
1.0.0-rc.1	The sample database reloaded clean	Its reload restarted a relying party's identifiers and reached the party's append-only record with neither, so each reload's first party inherited a dead party's history; a version-stamp check had guarded its comparison so that an unparseable version passed	`check_seed_restart_resets_dependent_records`, `check_roadmap_consistent`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-23	Every refusal a state-changing use case makes was mutation-tested	The drill selected stored procedures, and three use cases are functions because they return the id they create; their eleven refusals were measured by nothing, and several could be deleted with the suite green. Nine are caught now, one by a test that forces the lock interleaving it exists for; two are recorded	`check_procedure_refusals_are_mutation_tested` (extended to functions)
2026-09-23	A check fails the build if the token state machine's trigger stops being	Deleting each of the 42 triggers in turn left every check green for seven, the state machine and the active-signature guard among them; one check read a trigger's name and was satisfied by the comment beside it. Both core triggers are now pinned, with their legal transitions; four remain the drill's alone	`check_token_core_triggers_are_bound`, the trigger mutation drill
2026-09-23	The checks behind the constitution would notice their mechanism's loss	Each constraint's mechanism was broken in turn on the real tree; seven of ten checks let a break through. C1 took the append-only code anywhere in the schema, comments included; C3's drift checks took a deleted index by its `COMMENT ON`; C5 took `script-src 'self' https:`; C6 read the centroid's latitude and not its longitude; C7 missed a hardcoded copy beside the table; C8 missed a query whose row cap was removed; C10 saw money only as six words in table names, so a `stored_value` column on the credential passed. Each is closed and shown red; C2, C4 and C9 held	`check_aor_append_only_triggers`, `check_c1c10_objects_resolve`, `check_csp_forbids_unsafe_inline`, `check_c6_atlas_redacts_zk_location`, `check_crypto_algorithm_is_data`, `check_c8_atlas_caps`, `check_c10_no_money_tables`
2026-09-23	The published verifier's refusals were tested	32 of its 45 refusals could be turned into acceptances with every instrument CI runs on it green, the transparency log's consistency and inclusion checks among them; the forged-signature refusal of the one witness a stranger installs was hidden by a second witness the stranger lacks. Each is now driven by a test; seven declared	the SDK mutation drill, extended to the detached verifier

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-23	The day's repairs closed the gaps they were written for	Ten fresh mutations of the same mechanisms, written after the repairs, found four more that passed: a return placed before the audit refusal, an impossible predicate on the one-active-credential index, algorithm metadata under a new variable name, a row cap multiplied inside the query call. Each repair had closed an instance, not a class; all ten are caught now	`check_aor_append_only_triggers`, `check_one_active_token_index`, `check_crypto_algorithm_is_data`, `check_c8_atlas_caps`
2026-09-23	Tests aimed at inverted refusals covered the boundaries too	Semantic mutations that move a boundary rather than invert a refusal (a window opened a second early, a replay window doubled, an inclusion index off by one, a revocation lookup made case-sensitive, a disagreement between witnesses ignored) survived every instrument: 6 of 10 in the published verifier, 8 of 10 in each SDK, 8 of 10 in the OpenID4VP verifier, 6 of 10 in the zero-knowledge second witness, where the opening check could be deleted because the only test of it also failed the nullifier, and 10 of 10 in the conformance runner itself, which every instrument drove only with verifiers that were right: it could score a case on any one matching key, ignore `authentic`, count an omitted key as a match or stop voiding a run in which no genuine artifact was accepted, and nothing noticed. Each now has a test at the input that separates it from the code; all sixty are caught	the held-out tests in the verifier's, both SDKs', the OpenID4VP package's and the second witness's suites, the SDKs' over one shared signed fixture; `test_conformance_runner`, which drives the runner with verifiers wrong on purpose

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-23	The paths around the verifiers were tested where they refuse	The same kind of round on the code a relying party meets first: 8 of 10 in the packaged verifier's command line, whose exit codes, the one thing a script reads, no test read; 4 of 10 in the OpenID4VP verifier's transport; 9 of 12 in the SDKs' online decision, where a status check that failed with a network error returned accept in both; 3 of 10 in the card emulator, one of them equivalent (a tag equal to the last is a duplicate, and the duplicate check refuses it first); 4 of 10 in the card reader, where no test had ever reached an acceptance, so every refusal after the first stood behind it; and 5 of 7 in card personalization, where every check the database also makes was tested and none of the ones only the application makes. 58 of the 59 are caught now	`CommandLineExitCodes`, `HeldOutTransportTests`, the SDKs' online-decision tests, `TheAcceptingPathTests`, and five personalization tests with a card that misbehaves in one way
2026-09-23	A decision that combines facts refuses when any one of them fails	Every negative case in the suites and drills broke several facts at once, so a later refusal covered for an earlier one. Dropping one fact from a combined decision survived: in the detached verifier's offline decisions 26 of 50 (the stapled check, agent grants, the holder chain, the presentation, the cross-authority zero-knowledge decision), in the SDKs' holder, federation and timestamp-anchor checks 52 of 62, and in the relying-party endpoint 7 of 13, where the expiry, every status but REVOKED, the re-verification of the stored signature, the rate limit and the `usable` field were each unguarded. 124 of the 125 are caught now; the remaining one is equivalent	tests that give every other fact a passing answer and break one, over three new signed fixtures (a holder chain, federation variants, anchor variants)

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-23	The offline status assertion answered what the online endpoint answered	The online endpoint had read the expiry date since 2026-09-17; the route that signs status assertions, its sibling path, signed the stored status alone, and nothing moves a credential to EXPIRED when its date passes. A credential past its expiry got a fresh ACTIVE assertion that every offline verifier accepted, so the two answers to one question disagreed. The route now asserts EXPIRED and caps an ACTIVE assertion at the credential's last valid day; version 1.0.0-rc.8	`RelyingPartyApiTests`, failing on rc.7 and with the cap removed
2026-09-24	A migration run finished what it said it would	Migrating back onto an algorithm the population had left could not re-sign a credential already holding a deprecated signature under it: a credential holds one signature per algorithm and none changes. The run selected those credentials, wrote nothing for them, and stopped without an error, because a reused variable made its count of selected rows report the rows written; the window then refused to close with a message about finishing a migration no run could finish. They are now counted as blocked, the command names them and says to re-issue them, and the refusal says why; version 1.0.0-rc.9. Found by a held-out mutation round on the migration module, which also closed six survivors	`PopulationMigrationTests`, failing on rc.8; `MigratePopulationCommandTests`
2026-09-24	The sealed secret store wrote only where it was told	`unseal` joined each name in the unauthenticated manifest onto the tmpfs it materializes into, and under `age` anybody holding the public recipients can seal a blob, so a manifest naming `../escaped` wrote chosen bytes outside the tmpfs on every boot. Measured, then refused: a name that is not a plain file name refuses the whole store; version 1.0.0-rc.10. The same round found the key-management backend's two name bindings masking each other, because the rename test moved the blob and a missing file refused it first	`HeldOutSecretStoreTests`, failing on rc.9

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	A bound checked as a pair of comparisons held for every input	The console's cluster and hex-grid endpoints checked their size bound as `x <= 0 or x > 90`, which is False for NaN, so `?grid=nan` answered 200 with NaN in the body, collapsed every event into one cluster and put a key the cache could never match. Found by asking where else a NaN that had passed a sunset verdict's share check could live; both checks are now `not (0 < x <= 90)`; version 1.0.0-rc.11	`AtlasAPITests`, failing on rc.10
2026-09-24	Ending one authority's pilot touched only that pilot's people	A wind-down scoped to one authority pseudonymized every person who had ever held a credential from it, so somebody re-enrolled by a second authority on the same instance lost their name while that authority's credential stayed live, the state the wind-down exists to prevent. The only drill wound down a single authority on an instance serving nobody else. A participant still holding a live credential is now kept and counted; version 1.0.0-rc.12	`PilotWindDownTests`, failing on rc.11
2026-09-24	A session ended by a role change was ended	Since 2026-09-17 the session check ended a live session whose account's role changed, recording the reason `role_changed`, which the table's constraint did not admit: every request from the old session raised in the before-request hook, the revocation rolled back and the audit never recorded it. No test had changed a role during a live session; the held-out test written for that branch met the constraint. A migration admits the value; version 1.0.0-rc.13	`SessionLimitTests`, failing on rc.12

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	Every id space was sized	The capacity check stated that every sequence outlasted the 25-year horizon and had sized nine of forty: it read `CREATE TABLE IF NOT EXISTS` as a table named IF and skipped any table it had no growth rate for. Sized, three 32-bit sequences on the enrollment path ran out in 9.8, 9.8 and 14.7 years at the surge target. A migration widens them and recreates the two views that read them; every sequence now has a rate or a stated bound; version 1.0.0-rc.14	`check_capacity_model`
2026-09-24	An operator bound to one authority acted only as that authority	The guard for what a bound operator can make an authority do was called by two routes; nine routes took the acting authority from the request and never asked it, so an admin bound to one authority issued, revoked and recorded a trust attestation as another, which the ceremony signed under that other authority's key. Each now refuses, and a check fails any route that reads an acting authority from the request without the guard; version 1.0.0-rc.15	`check_operator_acts_only_as_its_authority`, `BoundOperatorActsOnlyAsItsAuthorityTests`
2026-09-24	A deactivated admin authorized nothing	Two procedures refused an actor whose account was deactivated; five others, among them the archive purge that is the one delete path into the append-only audit, checked the role alone, so a deactivated admin's user id, passed in by the command line or an operator script, still authorized them. Each now refuses; version 1.0.0-rc.16	`DeactivatedAdminHoldsNoAuthorityTests`, failing on rc.15

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	The code between a check and the database was tested	Held-out rounds on the code that sits between a refusal and the table it guards: in the trusted-referee module 8 of 12 survived, all in the functions that count and record vouchings, so the co-signer bound, which no database constraint can hold, was enforced by code no test ran; in enrollment codes 10 of 12, among them a lookup that would redeem another person's code; in the OpenID4VP package's command line 10 of 12, listener 7 of 12, decryptor 4 of 12 and request 3 of 12; in the transparency report's suppression 3 of 12. In each the tests had used one person, one code or one well-formed input, so nothing separated a scoped lookup from an unscoped one. All are caught now except four equivalents	drill rows with a second person and several codes; `HeldOutSuppressionTests`; the held-out classes in the OpenID4VP package
2026-09-24	A document somebody only looked at was not SUPERIOR evidence	How a document was verified to belong to the applicant capped what it contributed; how it was validated as genuine did not, so a passport an operator only inspected by eye counted as SUPERIOR and alone carried an IAL2 enrollment. Visual inspection now caps at FAIR and a physical-security-feature check at STRONG, as 800-63A grades validation; neither method had been used by any test; version 1.0.0-rc.17	`IdentityProofingTests`, two tests failing on rc.16
2026-09-24	A query an operator writes was not held to their authority	The row-level policies take a bound operator's scope from a session setting, and SQL can change a session setting even in a read-only transaction; the SQL console ran the operator's own text, so a bound admin or auditor could clear the setting in the query and read every authority's credentials. The console now refuses a bound account, and the isolation drill says the policies bound the queries the application issues, never SQL the operator writes; version 1.0.0-rc.18	`SQLConsoleTests`, failing on rc.17

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	Revocation's only door was a setting the caller could set	The trigger that makes the bounded revocation procedure the only way into REVOKED admitted any session that had set `polaris.revoke_check_done`, and the application role could set it and revoke with a plain UPDATE, skipping the rate bound and the co-signer; the default bound was likewise read from a setting the session could override. The revoking procedures now run with their owner's rights, the trigger admits only that owner, and the default is read as the database sets it; version 1.0.0-rc.19	`IssuerDiscretionBoundsTests`, two tests failing on rc.18
2026-09-24	A pilot's wind-down withdrew every credential	The wind-down revoked credentials whose status was ACTIVE, and a RESERVE credential is a pre-issued spare that can still be activated, so a finished wind-down left spares alive for people it had just erased, and an authority that had issued only spares was accepted as co-signer of its own pilot's end. The wind-down, its co-signer check and its drill now count ACTIVE and RESERVE together; version 1.0.0-rc.20	`PilotWindDownTests`, two tests failing on rc.19
2026-09-24	A migration moved every credential off a fallen algorithm	The population migration re-signed and then deprecated credentials whose status was ACTIVE, so a RESERVE spare, the credential a holder is moved onto when theirs is lost, stayed on the fallen algorithm alone, and activating one after the window closed issued a new credential on that algorithm; the drill's population held no spares and could not see it. Spares are now migrated with the population and the drill seeds them; version 1.0.0-rc.21	`PopulationMigrationTests`, failing on rc.20

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	A verification of a revoked credential could not be recorded as a success	The verification form refused a SUCCESS the federation trust graph did not support, because the audit-of-record would say something untrue, and never asked whether the credential was live: the issuing agency's SUCCESS against its own revoked token was recorded. The form now refuses a SUCCESS against any credential that is not ACTIVE, and still records a FAILURE; version 1.0.0-rc.22	`IssuerFederationTests`, failing on rc.21
2026-09-24	The verification form's liveness test matched the relying-party API's	The rc.22 guard refused a SUCCESS against a credential not ACTIVE and read status alone, but expiry is not written back to status, so a credential past its expiration date still read ACTIVE and a SUCCESS against it was recorded. The guard now calls the same validity test the relying-party API uses, ACTIVE and not expired; version 1.0.0-rc.23	`IssuerFederationTests`, failing on rc.22
2026-09-24	An expired credential could not sign its holder in	Nothing moves ACTIVE to EXPIRED when the date passes; the status assertion honoured the date from rc.8, but login, holder signing, holder-key binding, the verifiable credential and the mdoc read the stored status, so an expired credential obtained an authorization code and was attested usable. One function now answers whether a credential is live, and every one of those routes asks it; version 1.0.0-rc.24	`AuthBrokerTests`, `ZKSnarkTests`, failing on rc.23
2026-09-24	No card was made for a credential that had run out	Personalization refused a credential that was not ACTIVE so that no card is made for one the authority withdrew, and fetched the expiration date without reading it; an expired credential still reads ACTIVE, and a card was personalized for it. It now refuses one past its date, with the same inclusive rule the relying-party routes apply; version 1.0.0-rc.25	`CardPersonalizationTests`, failing on rc.24

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	A refused trust attestation was not recorded	The attestation route committed the new trust edge and only then signed it, so a signing failure answered with an error while the edge stood, recorded and unsigned; under the development signer every attestation toward an authority with a key did exactly that. The edge and its signature now commit together, and a signer naming no key leaves the edge unsigned instead; version 1.0.0-rc.26	`IssuerFederationTests`, two tests failing on rc.25
2026-09-24	Expiry was judged on one clock	The liveness test compared the expiry date with the server's local date while the signed status assertion ended validity at midnight UTC, so on a server outside UTC the online and offline answers disagreed for hours around every expiry and an assertion could be issued already expired. Both now read the UTC date; version 1.0.0-rc.27	`ZKSnarkTests`, failing on rc.26
2026-09-24	The database judged dates on the same clock	Attestation validity is judged in SQL against the session's current date, and nothing pinned the session's timezone, so a database initialised outside UTC judged trust on its local date while credentials and signed artifacts used UTC's. The database's timezone is now UTC for every session, by schema and by migration; version 1.0.0-rc.28	`ZKSnarkTests`, failing on rc.27
2026-09-24	Moving the database's clock broke nothing that assumed otherwise	rc.28 pinned the database to UTC, and two comparisons read its zoneless timestamps against the application's local clock on the premise that the two shared a zone: an expired ZK epoch read as still open, and a one-hour Atlas window took in an event three hours old. Both now ask the database's own clock, as the login lockout already did; version 1.0.0-rc.29	`ZKSnarkTests`, `AtlasFilterAPITests`, failing on rc.28

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	A bound administrator decided only its own authority's recoveries	Three operator routes name a token or a recovery request rather than an authority and never checked the binding: a bound admin rejected another authority's recovery, an approval had been refused only by the row-level policy that rc.19's elevation of the recovery procedure removed, and a migration re-signed another authority's token. Each now checks the binding against the authority the named thing belongs to; version 1.0.0-rc.30	`BoundOperatorActsOnlyAsItsAuthorityTests`, failing on rc.29
2026-09-24	Every state-changing operator route asked the binding	A sweep of every state-changing route an admin or operator can reach found three more that asked nothing: an admin bound to one authority changed another's name and authorization level, and could delete its record and its credentials. They now ask, and a new check fails the build on any such route that neither asks nor is declared instance-wide with a reason; version 1.0.0-rc.31	`BoundOperatorActsOnlyAsItsAuthorityTests`, failing on rc.30; `check_state_changing_routes_ask_the_binding`
2026-09-24	A status transition asked the binding about the token, not about an optional field	The transition route checked the operator's binding only against an optional actor field, so an operator bound to one authority who left it out moved another authority's credential to LOST, EXPIRED or DORMANT; the route check introduced at rc.31 counted it as bound. The route now asks about the token's own issuer, and the check requires every route that names a token to do so; version 1.0.0-rc.32	`BoundOperatorActsOnlyAsItsAuthorityTests`, failing on rc.31
2026-09-24	A bound operator could not revoke another authority's credential	The revocation and reserve-activation routes asked the binding about the actor they were told to act as, never about whose token it was; rc.19 had elevated both procedures past the row-level policy that used to hide the token, so an operator bound to one authority, naming itself as the actor, revoked another authority's credential. Both now ask about the token's issuer, and the route check requires it of every route that takes a token; version 1.0.0-rc.33	`BoundOperatorActsOnlyAsItsAuthorityTests`, failing on rc.32

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	An operational rate described the present	The per-minute rates behind the metrics endpoint and its alerts moved their window only when an event arrived, so after a burst of authentication failures the rate kept reporting the burst an hour later, and in the minute just after it read zero. Reading the rate now rolls the window to the present; version 1.0.0-rc.34	`RateWindowTests`, failing on rc.33
2026-09-24	A ZK epoch committed only credentials live through its end	Closing an epoch snapshotted credentials by their stored status alone, so an expired credential, and one expiring mid-epoch, were committed and could prove membership until the epoch ended. The snapshot now requires validity through the epoch's end, failing closed, and the liveness check reads SQL too; version 1.0.0-rc.35	`ZKSnarkTests`, failing on rc.34
2026-09-24	No device was bound to an expired credential	The device-binding procedure checked the credential's stored status and never its expiry, so a credential past its date still took a binding, as the relying-party key binding had not since rc.24; its test also exposed an earlier test that passed on a CHECK constraint rather than on the rule it named. Both are corrected; version 1.0.0-rc.36	`Uc5BindDeviceExpiryTests`, failing on rc.35
2026-09-24	No expired reserve was activated	Reporting a credential lost promoted the holder's reserve after checking its stored status and never its expiry, so a reserve past its date became a credential that read active and that every verifier refused; the state machine now refuses any activation past the expiration date, on every path; version 1.0.0-rc.37	`Uc4ReserveExpiryTests`, failing on rc.36
2026-09-24	The change records accepted no invented entry	The application role holds insert on the three change records because their recorders run as the caller, and that grant let it append a change nothing made, attributed to any database role it named; a direct insert is now refused and the role is always the session's own; version 1.0.0-rc.38	`test_the_change_records_accept_only_what_their_recorders_write`, failing on rc.37

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-24	The application could not set a person's enrollment status	A person's enrollment status is the latest entry in its log, and relying parties that require enrollment decide sign-in on it; the application role could append that entry directly and made a lapsed person enrolled with one insert; only the recording trigger or the owner writes it now; version 1.0.0-rc.39	`test_the_application_cannot_set_a_persons_enrollment_status`, failing on rc.38
2026-09-24	The audit of record could not be emptied through its partitions	The application role's loss of update and delete named the four partitioned event tables and not their partitions, which kept the blanket grant, and the append-only trigger honours a purge setting any role can set; with it the application deleted every row of all four through the partitions. Each partition is now read-only to it, including those made later, and the lifecycle log refuses its inserts too; version 1.0.0-rc.40	`test_no_partition_of_an_audit_table_can_be_emptied`, failing on rc.39
2026-09-25	No view showed a bound operator another authority's credentials	Reads by an operator bound to one authority are scoped by row-level security, and a view is evaluated with its owner's rights, so the policies beneath it did not apply: the investigation pages showed another authority's credential, its timeline and its verifications. Every view now runs as its caller; version 1.0.0-rc.41	`test_a_view_shows_a_bound_operator_no_more_than_the_tables_do`, failing on rc.40
2026-09-25	The database's rules held for a bound operator too	Seven routines enforced a rule by reading credentials that row-level security hides from an operator bound to one authority, so under that binding they saw nothing to refuse: a recovery opened for a holder with a live credential elsewhere, and another authority's active credential went onto the revocation list. They now run as their owner; version 1.0.0-rc.42	`test_a_rule_the_database_enforces_holds_for_a_bound_operator`, failing on rc.41

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-25	No bound operator bound a device to another authority's credential	The binding check for token routes read a lookup that found no row as permission, and for a bound operator row-level security hides another authority's credential rather than removing it; once the device-binding procedure ran as its owner (1.0.0-rc.40) it saw what the check could not, and a device was bound to another authority's credential. A hidden credential is now refused; version 1.0.0-rc.43	`test_no_route_acts_on_another_authoritys_credential`, failing on rc.42
2026-09-25	Binding an operator to an authority reached their live session	The authority an operator is bound to was read into the session at sign-in and never again, so binding an operator to one authority, which is how an incident narrows their reach, left their live session seeing every authority's credentials; the session now ends when the binding changes, as it has when the role changes; version 1.0.0-rc.44	`test_an_authority_binding_change_ends_the_live_session`, failing on rc.43
2026-09-25	Two operator features worked for the role a deployment runs as	The web and command-line suites ran as the schema owner, which bypasses row-level security and holds every privilege; run again as the application role, they found a retention command refused its own update and a simulation feature refused its bulk load, both failing on every call in any deployment while every test passed. Both go through the application role now, and the suites run as it in CI; version 1.0.0-rc.45	`scripts/polaris-app-role-suite.py`, failing on rc.44
2026-09-25	An epoch of one member hid nobody	An outside reviewer asked what happens when an epoch's anonymity set is too small; the answer was that it closed anyway, and a proof against an epoch of one identified its holder by elimination. An epoch below a minimum anonymity set (a database setting, twenty unless set) is now refused at close, and a proof against an older one answers privacy unavailable instead of verifying; version 1.0.0-rc.46	`test_an_epoch_below_the_minimum_anonymity_set_is_not_closed`, failing on rc.45

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-25	A skipped security test was a pass nobody read	The privilege-boundary tests had skipped in CI for want of a password while the run reported green; the constraint suite now fails, in CI, any test that would skip, and a check refuses the guard's removal; version 1.0.0-rc.46	`check_security_suite_refuses_skips_in_ci` and its detection test
2026-09-25	A client's timezone moved an expiry decision	The database's timezone was pinned to UTC as a default, which a client's timezone overrides; every expiry decision read the session's date, so with the session at UTC+14 an expired credential signed in. Decisions read a UTC date no session setting moves; version 1.0.0-rc.47	`test_a_session_timezone_does_not_move_an_expiry_decision`, failing on rc.46
2026-09-25	The product's own sessions wrote the environment's wall clock	Timestamp columns without a zone are filled in the session's zone, and the application, the command-line tool and the simulator took theirs from the environment; with it at UTC+14, issuing a credential that expires the same UTC day broke a time-order constraint. Each now pins its sessions to UTC before connecting; version 1.0.0-rc.48	`test_the_products_own_sessions_run_in_utc_whatever_pgtz_says`, failing on rc.47
2026-09-25	The anonymity floor had a side door	The floor lived in the procedure that closes an epoch, but the application's role could also write an epoch directly, including one whose stated size, which the verifier reads as the anonymity set, its members did not bear out. The procedure is now the only writer; version 1.0.0-rc.49	`test_app_role_writes_an_epoch_only_through_uc11`, failing on rc.48
2026-09-25	A trust edge could be recorded around the admin	The procedure that records federation trust checks for an admin, but the application's role could also insert a trust edge directly, which the signing pass would then sign with the authority's key, and could revoke one with a plain update. Both are now only through their procedures; version 1.0.0-rc.50	`test_app_role_records_and_revokes_trust_only_through_uc10`, failing on rc.49

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-25	An anchor could be moved between batches after they closed	The anchor table carried no trigger and the application's role could update it, so a closed batch's anchor could be moved into another batch and its proof rewritten, and a batch could be recorded whose size no leaves bore out. The application writes neither table; its role now cannot; version 1.0.0-rc.51	`test_app_role_cannot_write_the_anchoring_layer`, failing on rc.50
2026-09-25	A permanent record could be fabricated	Duress events, archive checkpoints and erasure records are append-only and written by procedures that refuse a false one, but the application's role could insert each directly: a duress alarm for a holder with no duress code, a purge that never ran, an erasure that never happened, none correctable. Each is now only through its procedure; version 1.0.0-rc.52	`test_app_role_cannot_fabricate_a_permanent_record`, failing on rc.51
2026-09-25	A credential could be created around issuance	Issuance signs with two witnesses and checks the algorithm authorization and the enrolment evidence, but the application's role could insert a credential directly, with permissions, and put tokens on the revocation list, bind devices and open recoveries around their procedures. It inserts none of these itself; now it cannot; version 1.0.0-rc.53	`test_app_role_cannot_create_a_credential_around_issuance`, failing on rc.52
2026-09-25	Three recovery channels were one role's word	A recovery is approved only when three independent out-of-band channels are recorded, and the application's role could record all three itself; it could also re-open a bulk batch already issued. It updates neither; now it cannot. No path in the product records the channels at all, which Section 19 now states; version 1.0.0-rc.54	`test_app_role_cannot_record_the_recovery_channels_or_reopen_a_batch`, failing on rc.53
2026-09-25	A revoked token could be taken off the list	Permissions and device bindings carried no trigger and the revocation list one only on status, and the application's role could update and delete all three without ever doing so: widen where a credential is valid, revive a device, or delete a revocation so no verifier feed listed it. Now it cannot; version 1.0.0-rc.55	`test_app_role_cannot_widen_revive_or_unrevoke_a_credential`, failing on rc.54

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-25	A credential could be moved to another person	The state machine guarded a token's status and nothing else, and the application's role, which updates status, could update the whole row: move an active credential to another person, extend it to 2099, or rewrite its value, issuer or duress code. Now every column but status is written only by the procedures; version 1.0.0-rc.56	`test_app_role_cannot_move_extend_or_rewrite_a_credential`, failing on rc.55
2026-09-25	An authority's key could be swapped without a trace	The key the trust list serves as active and the exchange gateway authenticates an institution by had one product writer, which logs the key first; the application's role could replace it with any key by a plain update, and nothing recorded it. Now the key changes only to one the authority's register holds, unretired and uncompromised; version 1.0.0-rc.57	`test_app_role_sets_an_authority_key_only_from_the_register`, failing on rc.56
2026-09-25	A retired algorithm could be revived	Nothing the application runs writes the algorithm registry or the authorizations that decide who may issue and co-sign, yet its role could: it un-deprecated a classical algorithm and relabelled it quantum-resistant, and could grant any authority the right to issue. Now only the owner writes them; version 1.0.0-rc.58	`test_app_role_cannot_revive_an_algorithm_or_grant_itself_one`, failing on rc.57
2026-09-25	A proof policy could be lowered	The contexts' proof requirements, which an authority signs into its registry, were writable by the application's role though nothing it runs writes them. Now only the owner writes them; version 1.0.0-rc.59	`test_app_role_cannot_lower_a_proof_policy`, failing on rc.58
2026-09-26	A recovery could not be approved through the product	rc.54 took the application's role's power to record the recovery ceremony's three channels, which was right, and left no path in the product to record them, so no recovery could reach approval without the schema owner. Now one procedure records each channel, attributed and gated per channel; version 1.0.0-rc.60	`test_a_recovery_completes_through_the_product_alone`, failing on rc.59

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-26	The constitution Athena shows could be rewritten	The rules C1–C10 and the map of which mechanism enforces each, which the Athena console shows operators, were writable by the application's role because the file that creates them loads after the grants. Now only the owner writes them; version 1.0.0-rc.61	`test_app_role_cannot_rewrite_the_constitution_athena_shows`, failing on rc.60
2026-09-26	A pending migration could be marked applied	The application's role could append an 'applied' event to the migration registry for a migration that had not run, and the next upgrade would have skipped it. Now only the migrator writes the registry; version 1.0.0-rc.62	`test_app_role_cannot_mark_a_migration_applied`, failing on rc.61
2026-09-26	The classical half's risk was stated as disclosure	Section 5 said a credential harvested today becomes readable when its classical signature falls. A signature encrypts nothing; the risk is forgery against verifiers that still accept that half, as PQC-POSTURE.md already stated	the sentence and the ledger now say forgery
2026-09-26	A referee's level was the writer's claim	The trusted-referee design says every limit is a database constraint. The referee's level was whatever the writer supplied and the co-signer bound lived only in the module: the application's role recorded 26 vouchings by an unproofed referee with no co-signer. The database now derives the level, bounds the count and checks the co-signer	`test_the_referee_level_is_derived_not_claimed`
2026-09-26	A proofing level could be typed	The schema says an assurance level is derived, never asserted, and nothing the application runs writes a proofing record; the application's role could still record an IAL2 proofing resting on no evidence. Now only the owner writes them	`test_app_role_cannot_assert_a_proofing_level`
2026-09-26	The application could lift its own revocation bound	The issuer-discretion design says a caller must not choose the bound it is held to. The application's role could supersede an authority's revocation bound and set it to 100% a day, under which no co-signer is ever asked for. Now only the schema owner sets the bounds	`test_app_role_cannot_choose_its_own_bounds`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-27	The application could grant itself an account	The application's role held table-wide write access to operator accounts, so a compromised application could create an admin, raise its own account to admin or reset the admin's password; each change was recorded, none prevented. It now updates only the lockout columns, and account management runs as the schema owner	`test_app_role_cannot_grant_itself_an_account`
2026-09-27	The application could register its own signing key	Nothing the web application runs writes the authority key register, card personalization or retention policy, and its role could: it registered an attacker's key and then made it the authority's signing key, a guard that only asked whether the register held the key; it bound its own keys to an active credential's card record; and it recorded a retention policy under an operator's name around the admin-only procedure. All three are now the owner's	`test_app_role_cannot_write_keys_cards_or_retention`
2026-09-27	The application could rewrite a relying party	Registering a relying party and setting its policy are the operator's command-line tasks, but the application's role could write the table, and the reason the database asks for when a policy is weakened is text the application writes itself. It turned a zero-knowledge-only relying party into a full-disclosure one and replaced its client secret. It now updates only the last-used time	`test_app_role_cannot_rewrite_a_relying_party`
2026-09-27	A revoked holder key could still authorize an agent	The offline verifier decided whether a delegated grant spoke for a real holder from the issuer's binding of that holder's key, but read the binding's signature, window and key and not its status. A grant signed with a key the issuer had revoked, the lost-device case, was reported bound and usable. It now requires an active binding, as the holder proof always did	the conformance case for a grant under a revoked binding

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-27	The connection pooler handed one operator's authority to the next request	The application keeps the operator's authority in the database session, and its design record says a pool without a reset would pass it to the next request. The production profile ran PgBouncer in transaction mode, which is that pool: a later, unrelated client read the previous operator's scope. It now runs in session mode with a reset between clients and refuses the other modes at start	`check_pooler_keeps_the_operator_scope`
2026-09-27	A receipt that named no context was authorized from any context	The offline verifier authorized an exchange's requester from a trusted attestation in the receipt's context, but a genuinely signed receipt with no context at all was authorized by an attestation from any context. The wire specification says the context must match. Only the responder's own key can sign such a receipt, and the instance never issues one; the verifier now requires the match, as it did for the request	the conformance case for a receipt with no context
2026-09-27	Any signed artifact could pass as a credential	A credential is signed over its token value, every other artifact over its JSON statement, and nothing separated the two. The signature of any artifact the authority published, re-wrapped as a credential whose token value is that statement, verified as authentic from a trusted issuer in every shipped verifier. A token value must now be a credential serial, checked before the signature by the verifiers, the issuer and the database	the transplant conformance case
2026-09-27	API errors outside a route were HTML	The API reference promised a JSON error body on every `/api` path; the framework's error handlers rendered the HTML page for every path, so an unhandled failure, an unknown path, an oversized body or a rate limit answered a relying party in HTML. The fault-injection measurement found it: every verification error during a database outage was an HTML page. The handlers now answer `/api` paths in JSON with the request id	the API error tests

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-27	The SDKs honoured an expired trust edge	A trust attestation is signed over its own window, and the wire specification says the window cannot be extended. The detached verifier had read it since 2026-09-17; both SDKs' cross-authority decisions never did, so an edge its authority had time-boxed kept granting acceptance while the manifest carrying it was fresh, and so did one whose window could not be read	the edge-window fixtures in both SDKs
2026-09-27	A missing context was a wildcard	The federation trust decision is in-context: the edge's context must equal the presented one. Every verifier treated no context as any context, so a relying party that read the context from a presentation accepted one that left it out under trust granted for another context	the no-context conformance case
2026-09-27	The verifier answered a question it had not asked	OpenID4VP keys a response by the id of the credential query the request made. The OpenID4VP verifier checked that the response held one entry and never compared its key, so a genuine presentation filed under any other name was taken as the answer. Found by mutating the real output of two independent wallets	the query-id regression test

Since 1.0.0-rc.66: claims taken literally

From `1.0.0-rc.66` most corrections came from adversarial review of the running tree and from sibling hunts: a sentence in a reference, a design record or a check, taken literally and run against real rows.

Table 6: Corrections recorded since `1.0.0-rc.66`. The right-hand column names the check, test or record that now fails if the original condition returns.

Version	What was believed	What was true, and what changed	The new sense
2026-09-28	A wallet copy named no operator	The architecture overview says a coerced operator's actions leave evidence. Offering a credential to a wallet returned a stateless code, and the copy's record named no operator, so an offer made under coercion left nothing behind. The offer is now recorded under the operator's account before the code is returned, and one that cannot be recorded is not made	`test_an_offer_is_recorded_under_the_operators_account`
2026-09-28	A proof dated NaN was fresh	The credential endpoint accepts a proof made in the last five minutes. A proof whose `iat` was NaN passed, because every comparison with NaN is false, and one nested past the parser was a 500 where the API reference promises `400 invalid_proof`. Both are refused	`test_a_proof_dated_nan_is_refused`
2026-09-28	`verify_presentation` never raises	A disclosure named by an array, and a non-string `vct` or `enc`, raised `TypeError` past it; each is now refused as malformed	`test_sdjwt`, `test_jwe`
2026-09-28	An unsigned trust edge that states a window is held to it	All three verifiers ignored an unsigned edge's `valid_until`; an edge that states one is now held to it, signed or not	`cross-authority-edge-window-unsigned-closed`
2026-09-28	An x5c credential's `iss` is its certificate's	Any `iss` passed under a trusted leaf; the leaf must now name it	`test_an_iss_another_certificate_names_is_refused`
2026-09-28	A signature's hex is read as hex	`bytes.fromhex` skipped whitespace, so a respaced genuine signature verified; one strict reader in all three	`pack-signature-hex-whitespace`
2026-09-30	The command line issued what nothing verifies	`polaris issue` reported success and stored the legacy placeholder where the signature belongs, so its credential could never verify; bulk enrollment signed, but not under the issuing authority's key. Both now sign as the issuing route does	`test_issue_signs_under_the_issuing_agencys_key`
2026-09-30	A NUL character was a server error	The API reference answers bad input with 400. A NUL character in a path, a query, a form field or a JSON string was a 500 on nine inputs, three of them on routes the reference covers. It is refused at the door	`test_a_nul_character_is_bad_input_not_a_500`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-30	The production image fetched its signing library	The security policy said Python's direct dependencies are pinned. The production image installed liboqs-python with no version, and the library fetched its native code by a movable tag at first import, unverified. Every package the images install now comes from a hash-pinned lock, the native library is built from a checked commit, and two checks that a comment had satisfied now read the instructions	`check_images_install_hashed_locks`, `check_prod_real_pqc`
2026-09-30	A login signed any context	Every other statement the instance signs takes its context from the credential's permissions. The login route signed whatever context the request named into the code its identity token is minted from, including one the credential was not permitted in and one that does not exist. It now requires the permission	`test_the_code_names_only_a_context_the_credential_is_permitted_in`
2026-09-30	A login's requirement was replaced, not added to	The API reference says a request may only add a requirement to the relying party's registered policy. A registered enrollment status replaced the requested one, and a requested value that was not a string was skipped, so a stricter ask was dropped without a word. Both now apply, and a malformed one is refused	`test_a_request_adds_an_enrollment_requirement_and_never_replaces_one`
2026-09-30	An operator could record a success no rule allows	The verification form refused a success the trust graph does not support and one against a dead credential, because the record would then say something untrue. It recorded one in a context the credential is not permitted in, and a selective-disclosure success that named no credential, although every rule reads the credential. Four older tests had used such contexts and would have hidden the rule each tests; each now breaks one rule	`test_a_success_is_not_recorded_in_a_context_the_credential_is_not_permitted_in`, `test_a_selective_success_names_its_credential`
2026-09-30	The sample recorded what the rules refuse	The sample's trust graph was said to explain its eight verifications. Two were successes across authorities with no attestation at all. The two missing attestations are in the sample, and a test holds every sample success to the rules	`test_every_seeded_success_is_one_the_rules_allow`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-30	The database boundary was said to cover the actor	The security controls said the purge's carve-out is out of the application role's reach, and the threat model said no definer routine exists. Twenty-four do, and those that record a governance act take the acting user as a parameter, so a compromised application can act as any administrator within their rules. The documents now say so; binding the actor is open	none yet: an open design decision
2026-09-30	`polaris-oid4vp serve` refuses TLS below 1.2	1.0.0rc9 on a Python 3.9 build accepted TLS 1.0 and 1.1; the floor is set explicitly	`test_it_refuses_tls_below_1_2_whatever_the_platform_default`
2026-09-30	The documented grant command decides the chain against `-issuer-anchor`	1.0.0rc5 exited 0 on a chain an attacker made end to end: the credential unverified, the anchor unread, missing links counted as passes; all five links must be checked	`agent-grant-use-principal-credential-forged`, `-no-credential`
2026-09-30	A stapled status assertion speaks for its credential	Any trusted key's assertion for the same token was accepted; it must be the credential's own key	`test_another_trusted_key_does_not_answer_for_this_credential`
2026-09-30	The verifiers read WIRE-SPEC's counts and inclusion proofs alike	Both SDKs ignored a bundle's `member_count`, and each verifier coerced an index, size or path its own way; one strict rule	`federation-status-bundle-count-mismatch`, `timestamp-anchor-proof-*`
2026-09-30	A manifest is trusted when a trusted anchor signed it	All three trusted one that merely listed a trusted anchor; only the signer counts	`cross-authority-manifest-lists-trusted-anchor`
2026-09-30	A signed edge is its authority's	Any key's valid signature counted; the key must be one of the authority's anchors	`cross-authority-edge-signed-by-a-stranger`
2026-09-30	A holder proof is about the credential presented	All three accepted a proof made for another credential under the same key; its `token_value` must match	`holder-chain-proof-for-another-credential`
2026-09-30	`-nonce` and `-trusted-anchor` apply to a presentation	Both were dropped on that path; a holder proof without a nonce now abstains	`test_a_presentation_with_a_holder_proof_is_held_to_this_services_nonce`
2026-09-30	A holder proof's age is a span of time	The TypeScript SDK read an offset-less instant in local time, so a seven-hour-old proof was fresh in one zone; read in UTC	`sdk.test.ts`: age read in UTC
2026-09-30	A signed statement meets WIRE-SPEC 3.9, 3.3 and 3.1	SHA-1 and uppercase digests, an impossible `issued_at` and a feed count unequal to its leaves passed; the manifest-signer rule held and nothing pinned it	`timestamp-digest-*`, `revocation-feed-count-*`, `federation-manifest-signed-by-a-stranger`
2026-09-30	A timestamp anchor's head is the log's signed tree head	Both SDKs took any artifact the log key signed; the format is checked first	`timestamp-anchor-head-is-not-an-sth`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-09-30	A cross-authority accept rests on the relying party's anchors	With none named, both SDKs trusted a manifest's own signature; they now trust none	`TrustComesFrom TheRelyingPartyTests`
2026-09-30	A holder chain answers the verifier's challenge	Both SDKs proved one with no nonce, or with a forged credential; both now refuse	`holder-chain-no-nonce`, `holder-chain-credential-signature-forged`
2026-09-30	The relying party asks the issuer about this credential	It asked by an id the holder could edit, and a revoked credential passed; it asks by possession and verifies the signed answer	`RelyingParty StatusBindingTests`
2026-09-30	A receipt's responder signed it	All three reported the responder a receipt named, whoever signed; now only once `responder_key` confirms	`exchange-use-receipt-responder-unconfirmed`
2026-09-30	A grant is honoured inside its window	The contract never asked, and both SDKs counted a binding with no window as fresh	`agent-grant-use-grant-expired`, `agent-grant-use-binding-without-window`
2026-10-01	A retention policy is recorded by the admin it names	The retention and purge routines took the acting admin as a parameter, so the application role could name any; they are the schema owner's	`test_the_app_role_cannot_set_retention`, `test_a_definer_routine_is_the_applications_alone_to_call`
2026-10-01	Only the holder changes the holder key	Possession of the credential rebound, rotated or revoked it, and every relying party that took a full presentation has that; a change now needs the live key's signature	`HolderKeyBindingTests`
2026-10-01	The holder key register holds what the route accepted	The application role could insert any event at any instant; the route now records events through one routine that sets the instant and keeps the order, and the role's own INSERT goes in a later release's migration	`test_the_holder_key_routine_keeps_events_in_order`
2026-10-01	`polaris-oid4vp` checks only the format it names, `dc+sd-jwt`	it also accepted `vc+sd-jwt`, which now names a W3C VC Data Model credential whose `validUntil` and `credentialStatus` it never reads, so an ended credential verified; refused	`test_a_w3c_vc_typed_credential_is_refused`
2026-10-01	every JWS here honours RFC 7515's `crit`	only the response JWE did (1.0.0rc12); the credential, its key binding JWT and a status list token verified with an extension they must not ignore	`test_a_crit_on_the_issuer_jwt_is_refused`, `CritTests`
2026-10-01	a key binding JWT is a valid JWT per RFC 7519 (RFC 9901 7.3)	its `exp` and `nbf` were never read; a proof expired an hour ago verified	`test_a_key_binding_jwt_past_its_exp_or_before_its_nbf_is_refused`
2026-10-01	a repeated digest is handled	the resolver memoized it, which bounded the work and decided nothing; RFC 9901 7.1 requires rejection, and one disclosure stood in two places	`test_a_digest_committed_twice_is_refused`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-10-01	an `x5c` leaf is an issuer's certificate	the trust anchor itself, a leaf carrying its key and a sub-CA all verified as issuers (HAIP 1.0 6.1.1)	`test_the_anchor_itself_sent_as_the_leaf_is_refused`, `test_a_ca_certificate_from_the_anchor_is_not_an_issuer`
2026-10-01	the three verifiers agree, and a drill proves it on hostile input	a signed `status` of `false` or `""` was active in the Python SDK and `polaris-verify` and not in the TypeScript SDK; the hostile drill cannot see it, because mutating a signed field breaks the signature and every verifier then refuses	`manifest-signer-status-*` and eleven more
2026-10-01	`polaris-verify` calls a grant usable only when it is	it never read the grant's limits, while `grant_within_limits` in the same module refuses a limit it does not understand	`AGrantWhoseLimitsAreNotUnderstoodIsNotUsableTests`
2026-10-01	a clean merge keeps the CHANGELOG right	a release cut renamed `Unreleased`, and a textual merge after it filed nine unreleased lines inside the released block; moved back, byte-identical to the release commit	#154
2026-10-01	a revoked leaf and an epoch leaf are each a SHA3-256 (WIRE-SPEC 3.3, 3.16)	no verifier checked; each turned any leaf into a string, and Python and JavaScript spell `null` differently, so one signed feed had two verdicts; a leaf is now 64 hex digits before any root is computed	`revocation-feed-leaf-*`, `epoch-leaves-leaf-not-hex`
2026-10-01	a signed document binds a lowercase SHA3-256 digest (3.12)	no verifier read the algorithm or the case; a document labelled MD5 was authentic in all three	`signed-document-digest-*`
2026-10-01	the TypeScript SDK reads an instant as the Python verifiers do	it rounded to the millisecond; a checkpoint issued 100 microseconds after `now` was fresh there and not yet valid in Python	`epoch-checkpoint-issued-microseconds-*`
2026-10-01	a use limit is a whole number in every verifier	both Python verifiers read 2.5 uses as 2	`GrantLimitsAreWholeNumbersTests`
2026-10-04	a credential verifies while its population migrates to a new algorithm (QUANTUM-EVENT.md)	under the development profile every migrated credential answered `signature_valid: false`, during the window and after it; the migration now writes issuance's placeholder	`test_a_migrated_credential_verifies_during_the_window_and_after_it`
2026-10-04	a holder's pack survives a migration that adds a signature	the possession proof compared the presented signature with the newest only; it now compares it, in constant time, with every signature in force	`test_the_pack_a_holder_carries_verifies_through_a_migration_window`
2026-10-04	a superseded signature stays valid for its grace period	closing a window cut it off at once; the doors now honour its deprecation date	`test_a_superseded_signature_verifies_until_its_deprecation_date`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-10-04	a credential's issuer facts describe the signature that answered	they came from an arbitrary signature dated by issuance; each signature now carries its own facts, dated by its own signing, and the route answers with the weakest	`test_J_the_credential_answers_with_the_weakest_of_its_signatures`
2026-10-04	the invariant checks read this tree	a nested checkout inside it (a cloned wallet, a vendored project) was read as Polaris and could fail or pass the build; directories carrying their own `.git` are now skipped	`test_nested_checkout_is_not_this_tree`
2026-10-10	the Foundation reviewed and published the certification (last ring)	it is a self-certification the Foundation approved and lists; both editions said *reviewed and published*, and the Russian edition's limitations line (Section 19) also said *not approved*. Both now say approved and listed, not endorsed or audited, and the math edition names who certified, as the certification terms allow	the three editions, read together
2026-10-10	the last ring is fourteen implementations	Axle's Kotlin OpenID4VP client, driven by a harness written here, joined on 2026-10-10 (the scoreboard's row of that date): fifteen, nine of them libraries, services and test tools. SpruceID's adapter and ERICA ran through their own wallet harnesses, not the holder built here; the math edition still counted one wallet and a conformance run awaiting review, as on 23 September	the three editions, read together

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-10-15	an mdoc's issuer signature is COSE -49, which RFC 9964 defines as pure ML-DSA-65 over the `Sig_structure`	The route signed SHA3-256 applied twice to the structure, so `verify_mdoc`, the mdoc verifier `polaris-verify` ships, refused every mdoc the route signed with real ML-DSA-65, and so did an ML-DSA-65 implementation not written here (pyca/cryptography) reading the raw structure. The mdoc drill was green because it signed with its own key over one SHA3-256 of the structure, the digest the verifier then checked, which is not what COSE -49 means either: it proved that the drill and the verifier agreed, not that either followed the format, nor that the route signs what the verifier checks. Under real signing no test handed the verifier an mdoc the route had made, and the placeholder profile the suites run by default makes no real signature. The issuer now signs the raw structure, the verifier checks only that, and the drill signs through the app's own signer and checks the result with the outside implementation	`MdocIssuerSignatureTests`, `check_mdoc_bridge`, RFC 9964's ML-DSA-65 example
2026-10-15	a verifiable credential's proof covers the bytes the detached verifier rebuilds (the VC format's design record)	The route signed SHA3-256 applied twice to the canonical bytes, so `verify_verifiable_credential`, which `polaris-verify` ships, refused every credential the route signed with real ML-DSA-65. The VC format drill was green for the mdoc drill's reason: it signed with its own single digest, which agreed with the verifier while the route did not, and under real signing no test handed the verifier a credential the route had made. The route now signs one SHA3-256 of the bytes; a test posts to it and asks the shipped verifier first, and the drill signs through the app's signer and refuses the twice-hashed proof	`VerifiableCredentialProofTests`, `check_vc_format`

continued on the next page

Version	What was believed	What was true, and what changed	The new sense
2026-10-21	every read path returns no location for a zero-knowledge event (C6; Property 7 of the math edition)	The row stores the location the verifier states, as the operator privacy notice publishes, and two places return it as stored: the admin and auditor SQL console, which runs the caller's own query, and the owner-role archive export. The checks pin the Atlas functions and the page queries that name a location; the two investigation pages read views keyed by token or holder, which a zero-knowledge row never matches (C2), and render no location. The redaction property suite runs its adversary over the stored rows, not over any route; nothing measured *every read path*. The three editions now say, as the site, the readiness ledger, the threat model and the redaction proof do, that the application's pages other than that console return no location	`check_c6_app_read_paths_redact`, `check_c6_atlas_redacts_zk_location`, `docs/operator/PRIVACY.md`
2026-10-24	nothing floors an epoch's anonymity set above one, and no verdict mentions it (the privacy section's linkability results, the boundaries, the agents' summary, the research agenda, the limitations, the glossary and the status table)	Since `1.0.0-rc.46` an epoch below the minimum anonymity set, twenty unless set (the notional sample sets one), is not closed, and the online verifier and the detached verifier's cross-authority path answer a proof against a smaller one *privacy unavailable*; since `1.0.0-rc.49` the application role writes an epoch only through the closing procedure. The privacy section's construction paragraph and the math edition stated the floor, and these seven places, like the readiness ledger, denied it: the error understated the system. What holds is that above the floor no verdict reports the set's size, and the seven places and the ledger now say so	`test_an_epoch_below_the_minimum_anonymity_set_is_not_closed`, `test_a_proof_against_an_epoch_below_the_floor_is_privacy_unavailable`, `test_app_role_writes_an_epoch_only_through_uc11`

Several corrections in the record are about the project's posture rather than a mechanism. At `v9.55` the repository deleted eighteen thousand lines of self-monitoring apparatus and some nine hundred invariants that asserted the apparatus's claims about itself; at `v9.453`, three hundred and ninety-seven versions later, forty-six references in twenty-four live files still cited the deleted documents as the authority for a rule, one of them in an error message an operator reads. At `v9.332` the phrase *zero-knowledge identity system* was split into three claims. At `v9.452` *post-quantum* on the front door became *algorithm agility under an audited migration path*, and at the lab's assessment of 13 September 2026 *compulsion-resistant* became *duress-aware*, each with a check that refuses the stronger word. And at `1.0.0-rc.1` the version number stopped counting

ships: 9.467 had been bumped by the change that added a check and the change that fixed a comment alike, and under the operating contract a version marks an externally observable change, which is rare.

Dates moved out of the body

The body states what each mechanism is; these are the dates it no longer carries.

- `v9.347`: the recovery request's decision fields became one-way under a trigger.
- `v9.349`: a credential may bind a holder-controlled key (`HolderKeyEvent`).
- `v9.354`: the epoch leaf became a Poseidon commitment the circuit opens; before it the leaf was a `SHA3-256` digest handed in as an opaque value, so a nullifier proved nothing about it, and epochs closed under the old derivation were re-closed.
- `v9.361`: the proof library was evaluated against its successor and kept.
- `v9.366`: the card became an encoding, an emulator and a personalization step.
- `v9.374`: C3 gained a formal model checked on every push.
- `v9.382`: the warrant read, which sat behind a stored procedure and had left no record of its own use, began writing the same audit row as every other read.
- `v9.408`: the reconstruction-risk assertion was reshaped after two weaknesses in its adversary were found invisible to the old shape.
- `v9.425`: a relying party's bar, which could be lowered with nothing recorded, became a recorded decision.
- The lifecycle figure of Version 1 omitted the revocation of a reserve token, which the trigger has always allowed; Version 1 recommended the transition trigger as future work.
- 25 September 2026: the minimum anonymity set; before it an epoch of one member closed, and a proof against it hid nobody.
- `v9.58`: the headline post-quantum claim was, at the data level, a hardcoded string, and the real signing module an unused island until it was wired into issuance.
- `v9.280`: a production boot fails closed unless real signing is available.
- `v9.359`: region B became a standby cluster.
- `v9.387`: every capacity extrapolation carries its assumption by name.
- `v9.404`: the application-to-pooler hop negotiates a post-quantum key exchange, read off a real handshake; the posture ledger had called it classical.
- `v9.419`: the cryptographic witnesses became mutation-tested.
- `v9.424`: a quota became a decision with a reason.
- Version 2 called Polaris post-quantum on its cover; the subsection on agility replaced the word after an outside argument (Appendix D). Version 2 described `polaris-verify` as a script in the repository, and its honest boundary was that no external implementation had interoperated.
- The log-content promise (no form body, cookie or token value) was kept by discipline alone until a check began reading the logging calls; the column-writer check was wrong about three columns in its first version.
- Until 23 September 2026 the password rotation changed the file first, and a live stack the script took for stopped was left presenting a password the database had never been told.

- Twenty-two drills printed their verdict from zero recorded cases; a CI job failed on its own setup rather than on a finding; the local gate ran four suites while CI ran eighteen and shipped a broken change twice.
- 15 September 2026: the conformance run. Its first write-up said eleven of eleven clean, and it was false in a flattering direction: one fixed alias had been used for every module, the suite interrupts a test when another starts under the same alias, and the four positives had been killed by their successors, which the suite had recorded in the very log downloaded to corroborate the claim. It was re-run one module at a time. Certified on 24 September 2026 against `polaris-oid4vp 1.0.0rc7`.
- 15 September 2026: the walt.id Wallet API v2 exchange; the key-usage fix the same day was the first fix on the scoreboard caused by an external finding, and an outside reviewer's, two days later, the second.

The walls, asked whether they would notice

Version 2 described the checks and stopped there. Between `v9.398` and `v9.437` the repository asked the layer the question it asks everything else, not *does it pass* but *would it notice*, and the answer was often no. Commenting out the lines carrying a check's search strings, which is exactly what a temporarily disabled line looks like, left 71 of 75 checks green, because the helper every check reads through handed it the comments along with the code. Dropping each of the 46 CHECK constraints found every one load-bearing, which was the good news; dropping each of the 37 triggers found 14 that nothing noticed, twelve of them the append-only guards that C1 *is*; dropping each of the 17 unique indexes found twelve uncovered, and stopped on the second, because with `uq_one_active_per_person` absent the suite that exists to prove C3 had inserted and committed a second active token for one person and the index could not be rebuilt. Deleting each of the 59 refusals the sixteen stored procedures make found 27 that no test would miss, concentrated exactly where a trigger cannot see: the four-eyes rule, the cool-down, the three channels and the third-person witness of the recovery ceremony, the preconditions on an irreversible erasure. Every one of these is now covered. The drill selected procedures only, and three of the use cases, issuance, reserve activation and device binding, are functions, because they return the id they create; their eleven refusals sat outside it until 23 September 2026. Among the ones no test noticed were the check that an agency is authorized for the algorithm it issues under and the check that a reserve token belongs to the same person as the credential it replaces. Nine are covered now. One of them, the reserve check the routine repeats under its lock, can fire only if another transaction moves the reserve while the routine waits, so its test holds the lock itself, waits until the routine is seen blocked on it, revokes the reserve and lets go. The two that remain are the copies of its two status checks made before the lock, which on one connection refuse exactly when their twins do. Every one of these measurements is now a drill that runs on every push with a negative control, so that a result of zero survivors is distinguishable from a harness that ran nothing. Twelve such drills exist at `1.0.0-rc.7`: over the checks, the constraints, the triggers, the procedures, the zero-knowledge witnesses, the conformance contract, the two reference verifiers, the OpenID4VP verifier, the application, the constitutional constraints, the surfaces a check quantifies over, and the moves of code between modules.

More dates moved out of the body

- `v9.412` (walls): C1 is tested once per table that claims it.
- `v9.405` (walls): also asserts that the check passes on the same fixture unbroken, because a test that…
- `v9.264` (authorization): the status that decides `usable` is pinned to the primary, the response names its…
- `v9.358` (authorization): a cache directive is never a constant: every windowed artifact's `max-age` is its…
- `v9.357` (authorization): the padding is one repeated value hashed once per level, and a root over a million…
- `v9.425` (use): a relying party is also an object about which decisions are recorded: registering one…
- `v9.336` (use): the policy is registered on the relying party's row and applied first: a request may add…
- `v9.353` (use): not the same value at every relying party.
- `v9.382` (transparency): the authority can publish a transparency report that says how often it used that power…
- `v9.333` (institutions): the responding agency itself must attest the requester's key in the envelope's context…
- `v9.341` (institutions): a caller may choose to anchor: the timestamp's own hash joins an append-only, witnessed…
- `v9.402` (cognition): the benchmark times every bounded aggregate at a tenth of the event stream and at all of…
- `v9.364` (boundaries): an operator bound to one authority even inside a shared instance.
- `v9.331`: an outside review found that a relying party's demands travelled only in the holder-side request and bound nothing, and that the authorization code was signed but readable; `v9.336` registered the policy on the relying party's row.
- `v9.364`: a review of a shared instance found operator accounts with no authority binding and sixteen of seventy-four operator routes reading credential or holder data with no issuing-agency filter; the binding and the filters followed, and row-level security in the schema (1.0.0-rc.38 to rc.45) made the database the boundary for a bound session.
- Version 2 could tell a reader how to run Polaris from a clone; the stranger's path came after.
- `v9.353`: the login token's subject had been the credential's hash, the same value at every relying party; it became derived under the relying party's own scope.
- `v9.371`: before it the system could issue a credential with no record of how the person was proven; enrolment proofing and evidence followed.
- `v9.376`: the pilot wind-down; `v9.381`: the coexistence plan; `v9.384`: the planning targets checked against the throughput model.
- `v9.422`: creating an operator account had left no record, and six of the twenty-one audit event types had no writer anywhere in the tree.